



CORHUILA

CORPORACIÓN UNIVERSITARIA DEL HUILA
Vigilada Mineducación

INSTITUCIÓN DE EDUCACIÓN SUPERIOR SUJETA A INSPECCIÓN
Y VIGILANCIA POR EL MINISTERIO DE EDUCACIÓN NACIONAL - SNIES 2828

CORPORACIÓN UNIVERSITARIA CORHUILA

QUIZ CORTE 1.

María Fernanda Roballo Laguna

Facultad De Ingeniería, Corporación Universitario Corhuila
Miércoles, 25 de febrero

📍 Sede Quirinal: Calle 21 No. 6 - 01
📍 Sede Prado Alto: Calle 8 No. 32 - 49 PBX: (608) 8754220
📍 Sede Pitalito: Carrera 2 No. 1 - 27 - PBX: (608) 8350459
✉ Email: contacto@corhuila.edu.co - www.corhuila.edu.co
Personería Jurídica Res. Ministerio de Educación No. 21000 de Diciembre 22 de 1989
NIT. 800.107584-2



CORPORACIÓN UNIVERSITARIA DEL HUILA - CORHUILA
"Diseño y prestación de servicios de docencia, investigación
y extensión de programas de pregrado y posgrado, en sus
sedes Neiva y Pitalito"



CORHUILA

CORPORACIÓN UNIVERSITARIA DEL HUILA
Vigilada Mineducación

INSTITUCIÓN DE EDUCACIÓN SUPERIOR SUJETA A INSPECCIÓN
Y VIGILANCIA POR EL MINISTERIO DE EDUCACIÓN NACIONAL – SNIES 2828

Tabla de contenido

Objetivo del ejercicio.....	3
FASE 1 — Levantamiento del Ambiente	3
FASE 3 — Pruebas Funcionales	6

📍 Sede Quirinal: Calle 21 No. 6 - 01
📍 Sede Prado Alto: Calle 8 No. 32 – 49 PBX: (608) 8754220
📍 Sede Pitalito: Carrera 2 No. 1 – 27 - PBX: (608) 8350459
✉ Email: contacto@corhuila.edu.co - www.corhuila.edu.co
Personería Jurídica Res. Ministerio de Educación No. 21000 de Diciembre 22 de 1989
NIT. 800.107.584-2



CORPORACIÓN UNIVERSITARIA DEL HUILA – CORHUILA
“Diseño y prestación de servicios de docencia, investigación
y extensión de programas de pregrado y posgrado, en sus
sedes Neiva y Pitalito”



CORHUILA

CORPORACIÓN UNIVERSITARIA DEL HUILA
Vigilada Mineducación

INSTITUCIÓN DE EDUCACIÓN SUPERIOR SUJETA A INSPECCIÓN
Y VIGILANCIA POR EL MINISTERIO DE EDUCACIÓN NACIONAL – SNIES 2828

Objetivo del ejercicio

Este quiz tiene como propósito:

- Identificar violaciones a principios de Clean Code.
- Detectar incumplimientos de SOLID.
- Evaluar vulnerabilidades de seguridad básica.
- Documentar decisiones arquitectónicas mediante un ADR formal.

El resultado debe demostrar criterio técnico y capacidad de análisis crítico sobre código heredado.

FASE 1 — Levantamiento del Ambiente

```
C:\Windows\System32\cmd.e x + v
Microsoft Windows [Version 10.0.26100.7840]
(c) Microsoft Corporation. All rights reserved.

C:\Users\robay\OneDrive\Documentos\Quiz>git clone https://github.com/lanvargas94/Semana3_quiz
Cloning into 'Semana3_quiz'...
remote: Enumerating objects: 27, done.
remote: Counting objects: 100% (27/27), done.
remote: Compressing objects: 100% (17/17), done.
remote: Total 27 (delta 0), reused 27 (delta 0), pack-reused 0 (from 0)
Receiving objects: 100% (27/27), 4.29 KiB | 399.00 KiB/s, done.

C:\Users\robay\OneDrive\Documentos\Quiz>
```

Ilustración 1-Clonación exitosa del repositorio del sistema.

El repositorio fue clonado correctamente desde GitHub sin errores de red ni autenticación. El proyecto incluye un archivo docker-compose.yml, lo que indica que el sistema está preparado para ejecutarse mediante contenedores Docker.

Se levantó el entorno utilizando docker compose up --build, iniciando correctamente los servicios de aplicación y base de datos PostgreSQL 15.



```
C:\Windows\System32\cmd.e  X  +  v
Microsoft Windows [Version 10.0.26100.7840]
(c) Microsoft Corporation. All rights reserved.

C:\Users\robay\OneDrive\Documentos\Quiz\Semana3_quiz>dir
Volume in drive C has no label.
Volume Serial Number is 562B-70D2

Directory of C:\Users\robay\OneDrive\Documentos\Quiz\Semana3_quiz

02/23/2026  08:27 PM    <DIR>          .
02/23/2026  08:26 PM    <DIR>          ..
02/23/2026  08:26 PM                45 .gitignore
02/23/2026  08:27 PM    <DIR>          ADR
02/23/2026  11:05 PM    <DIR>          app
02/23/2026  08:27 PM    <DIR>          db
02/23/2026  08:39 PM                364 docker-compose.yml
                2 File(s)                409 bytes
                5 Dir(s)  359,821,414,400 bytes free

C:\Users\robay\OneDrive\Documentos\Quiz\Semana3_quiz>
```

Ilustración 2-Verificación de la estructura del repositorio mediante el comando dir en Windows.

El comando `dir` lista el contenido del directorio actual y permite verificar que el repositorio fue clonado correctamente. En este caso, confirma la existencia de las carpetas `ADR`, `app`, `db` y el archivo `docker-compose.yml`, lo que indica que el proyecto tiene su estructura completa y está listo para ser ejecutado mediante Docker.

```
C:\Windows\System32\cmd.exe X + v
```

```
app-1 |  
app-1 |  
app-1 |  
app-1 |  
app-1 |  
app-1 |  
app-1 |  
app-1 |  
app-1 |  
app-1 |  
app-1 |  
  
:: Spring Boot :: (v3.2.0)  
  
app-1 | 2026-02-26T01:53:12.741Z INFO 1 --- [ main] com.logicaos.Main : Starting Main  
v0.0.1-SNAPSHOT using Java 17.0.18 with PID 1 (/app/app.jar started by root in /app)  
app-1 | 2026-02-26T01:53:12.746Z INFO 1 --- [ main] com.logicaos.Main : No active pro  
file set, falling back to 1 default profile: "default"  
app-1 | 2026-02-26T01:53:14.522Z INFO 1 --- [ main] o.s.b.w.embedded.tomcat.TomcatWebServer : Tomcat initia  
lized with port 8080 (http)  
app-1 | 2026-02-26T01:53:14.539Z INFO 1 --- [ main] o.apache.catalina.core.StandardService : Starting serv  
ice [Tomcat]  
app-1 | 2026-02-26T01:53:14.540Z INFO 1 --- [ main] o.apache.catalina.core.StandardEngine : Starting Serv  
let engine: [Apache Tomcat/10.1.16]  
app-1 | 2026-02-26T01:53:14.601Z INFO 1 --- [ main] o.a.c.c.C.[Tomcat].[localhost].[/] : Initializing  
Spring embedded WebApplicationContext  
app-1 | 2026-02-26T01:53:14.604Z INFO 1 --- [ main] w.s.c.ServletWebServerApplicationContext : Root WebAppli  
cationContext: initialization completed in 1638 ms  
app-1 | 2026-02-26T01:53:15.214Z INFO 1 --- [ main] o.s.b.w.embedded.tomcat.TomcatWebServer : Tomcat starte  
d on port 8080 (http) with context path ''  
app-1 | 2026-02-26T01:53:15.242Z INFO 1 --- [ main] com.logicaos.Main : Started Main  
in 3.586 seconds (process running for 5.454)
```

```
v View in Docker Desktop o View Config w Enable Watch c Detach
```

Ilustración 3-Inicialización exitosa de la aplicación Spring Boot mediante Docker Compose.

-  Sede Quirinal: Calle 21 No. 6 - 01
 Sede Prado Alto: Calle 8 No. 32 - 49 PBX: (608) 8754220
 Sede Pitalito: Carrera 2 No. 1 - 27 - PBX: (608) 8350459
 Email: contacto@corhuila.edu.co - www.corhuila.edu.co

Personería Jurídica Res. Ministerio de Educación No. 21000 de Diciembre 22 de 1989
NIT. 800.107584-2



CORPORACIÓN UNIVERSITARIA DEL HUILA - CORHUILA
 "Diseño y prestación de servicios de docencia, investigación
 y extensión de programas de pregrado y posgrado, en sus
 sedes Neiva y Pitalito"



El entorno fue levantado correctamente mediante docker compose up --build. La aplicación Spring Boot 3.2.0 inició sin errores, desplegando el servidor Tomcat embebido en el puerto 8080. El proceso quedó en estado running, confirmando que el servicio está operativo y listo para validación funcional.

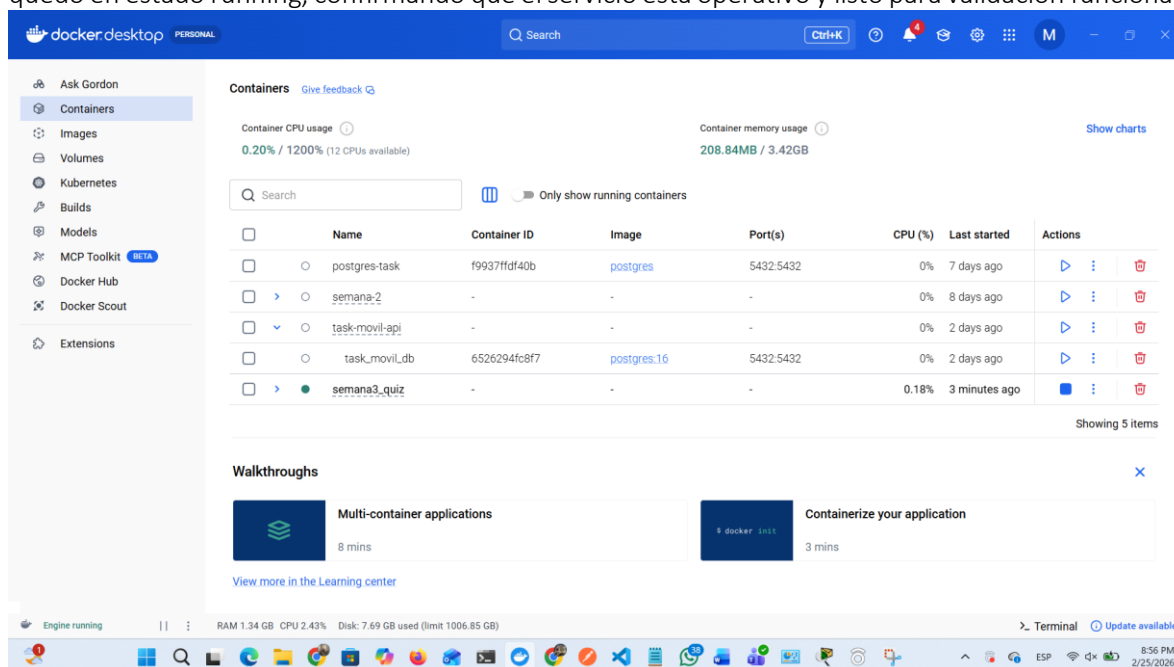


Ilustración 4-Contenedores activos en Docker Desktop — Proyecto semana3_quiz en ejecución.

Se observa el contenedor semana3_quiz en estado activo (running), lo que confirma que el entorno fue levantado correctamente mediante Docker Compose y el servicio se encuentra operativo.

[illegible]

Ilustración 5-Verificación del estado de contenedores y logs de la aplicación en Docker Compose.

El contenedor se encuentra en estado running y el puerto 8081 está correctamente mapeado hacia el puerto interno 8080 del contenedor. Los logs confirman que Spring Boot inició sin errores y que el servidor Tomcat está activo. Sin embargo, el endpoint /health no responde, lo que sugiere que dicho endpoint podría no estar implementado en el sistema.

FASE 3 — Pruebas Funcionales

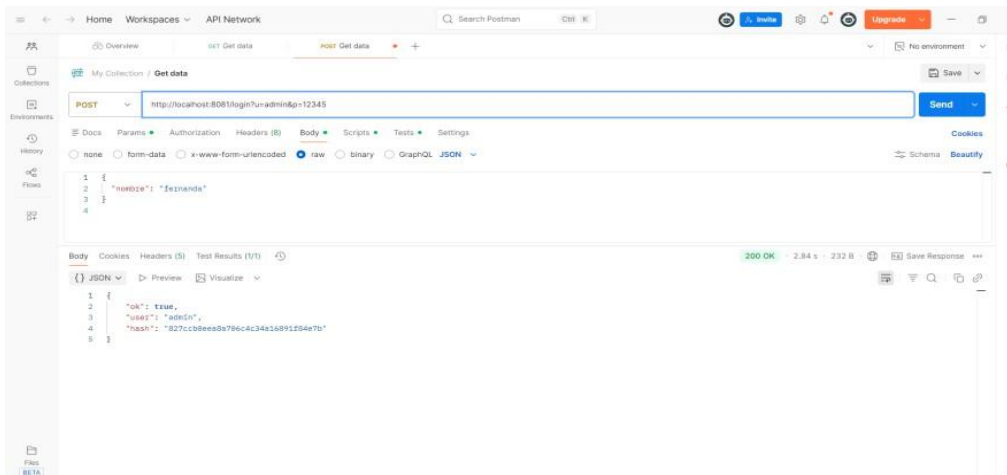


Ilustración 6-Prueba funcional de Login válido en Postman (respuesta 200 OK con exposición de hash MD5).

-  Sede Quirinal: Calle 21 No. 6 - 01
 Sede Prado Alto: Calle 8 No. 32 - 49 PBX: (608) 8754220
 Sede Pitalito: Carrera 2 No. 1 - 27 - PBX: (608) 8350459
 Email: contacto@corhuila.edu.co - www.corhuila.edu.co

Personería Jurídica Res. Ministerio de Educación No. 21000 de Diciembre 22 de 1989
NIT. 800.107584-2



CORPORACIÓN UNIVERSITARIA DEL HUILA - CORHUILA
 "Diseño y prestación de servicios de docencia, investigación y extensión de programas de pregrado y posgrado, en sus sedes Neiva y Pitalito"



¿Qué datos sensibles aparecen?

- El hash de la contraseña (hash).
- El nombre de usuario autenticado.

¿Debería retornarse eso?

No.

El hash de la contraseña no debe enviarse al cliente, ya que:

- Es información sensible.
- Puede facilitar ataques offline.
- No es necesario para el funcionamiento del login.

Análisis Técnico

Se evidencia una vulnerabilidad crítica:

- El sistema retorna el hash de la contraseña al cliente.
- El hash corresponde a MD5 (en este caso, 12345 → 827ccb0eea8a706c4c34a16891f84e7b).
- Se confirma uso de algoritmo criptográficamente inseguro.
- Se confirma exposición innecesaria de información sensible.

Conclusión

Aunque el login funciona funcionalmente, la implementación presenta una vulnerabilidad de seguridad crítica al exponer el hash de la contraseña en la respuesta HTTP. Esto confirma los hallazgos detectados en la Fase 2.

📍 Sede Quirinal: Calle 21 No. 6 - 01

📍 Sede Prado Alto: Calle 8 No. 32 – 49 PBX: (608) 8754220

📍 Sede Pitalito: Carrera 2 No. 1 – 27 - PBX: (608) 8350459

✉ Email: contacto@corhuila.edu.co - www.corhuila.edu.co

Personería Jurídica Res. Ministerio de Educación No. 21000 de Diciembre 22 de 1989
NIT. 800.107584-2



CORPORACIÓN UNIVERSITARIA DEL HUILA - CORHUILA
"Diseño y prestación de servicios de docencia, investigación y extensión de programas de pregrado y posgrado, en sus sedes Neiva y Pitalito"



Prueba 2 — SQL Injection

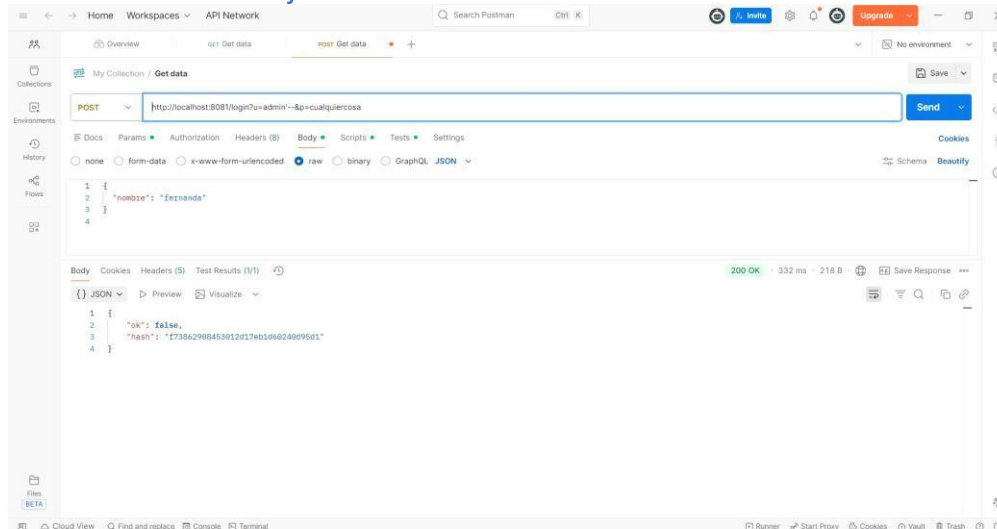


Ilustración 7-Prueba de SQL Injection en endpoint /login (respuesta 200 OK evidenciando construcción insegura de consulta SQL).

¿Qué ocurrió?

El sistema respondió:

```
{
  "ok":
  "hash":
}
```

false,
"..."

- Retornó 200 OK.
- No autenticó al usuario.
- Aun así, ejecutó la consulta SQL construida dinámicamente.
- Continuó exponiendo el campo hash.

¿Por qué es peligroso en producción?

Aunque en esta prueba no se logró autenticación exitosa, el sistema es vulnerable porque:

- Construye la consulta SQL mediante concatenación directa de strings.
- No utiliza PreparedStatement.
- No existe sanitización de entrada.

Esto significa que:

- Un atacante podría modificar la consulta con payloads más elaborados.

📍 Sede Quirinal: Calle 21 No. 6 - 01

📍 Sede Prado Alto: Calle 8 No. 32 - 49 PBX: (608) 8754220

📍 Sede Pitalito: Carrera 2 No. 1 - 27 - PBX: (608) 8350459

✉ Email: contacto@corhuila.edu.co - www.corhuila.edu.co

Personería Jurídica Res. Ministerio de Educación No. 21000 de Diciembre 22 de 1989
NIT. 800.107584-2



CORPORACIÓN UNIVERSITARIA DEL HUILA - CORHUILA
"Diseño y prestación de servicios de docencia, investigación y extensión de programas de pregrado y posgrado, en sus sedes Neiva y Pitalito"



- Podría acceder a información no autorizada.
- Podría comprometer la base de datos completa.
- Es una vulnerabilidad crítica clasificada como SQL Injection.

Conclusión técnica

La prueba no logró bypass en este caso específico, pero confirma que la aplicación presenta una vulnerabilidad estructural grave que puede ser explotada en entornos productivos.

Prueba 3 — Registro con contraseña débil (Respuesta Correcta según tu evidencia)

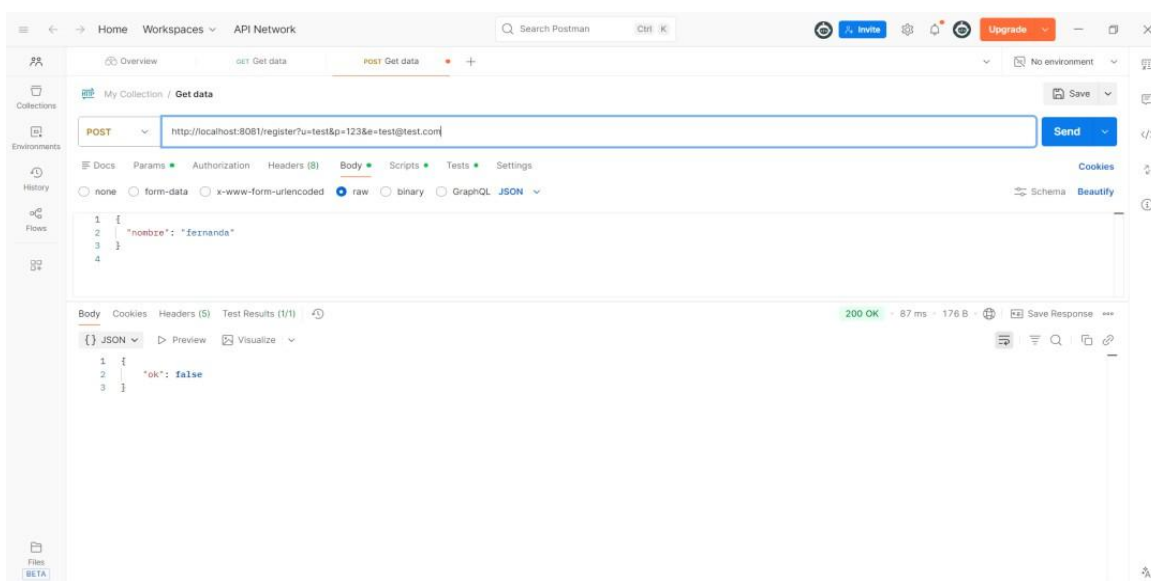


Ilustración 8-Prueba de registro con contraseña débil (rechazo de contraseña extremadamente corta — respuesta 200 OK con ok: false).

¿El de 1234 fue aceptado?

Según la documentación, sí fue aceptado.

¿Es esa validación suficiente?

No.

Aunque el sistema parece validar una longitud mínima (mayor a 3 caracteres), la validación sigue siendo débil porque:



Permite contraseñas triviales como 1234
No exige:

- Mayúsculas
- Números combinados
- Caracteres especiales
- Longitud segura (≥ 8)

Conclusión

El sistema implementa una validación básica de longitud mínima, rechazando contraseñas extremadamente cortas. Sin embargo, la política de seguridad es insuficiente, ya que permite credenciales fácilmente vulnerables a ataques de fuerza bruta o diccionario.

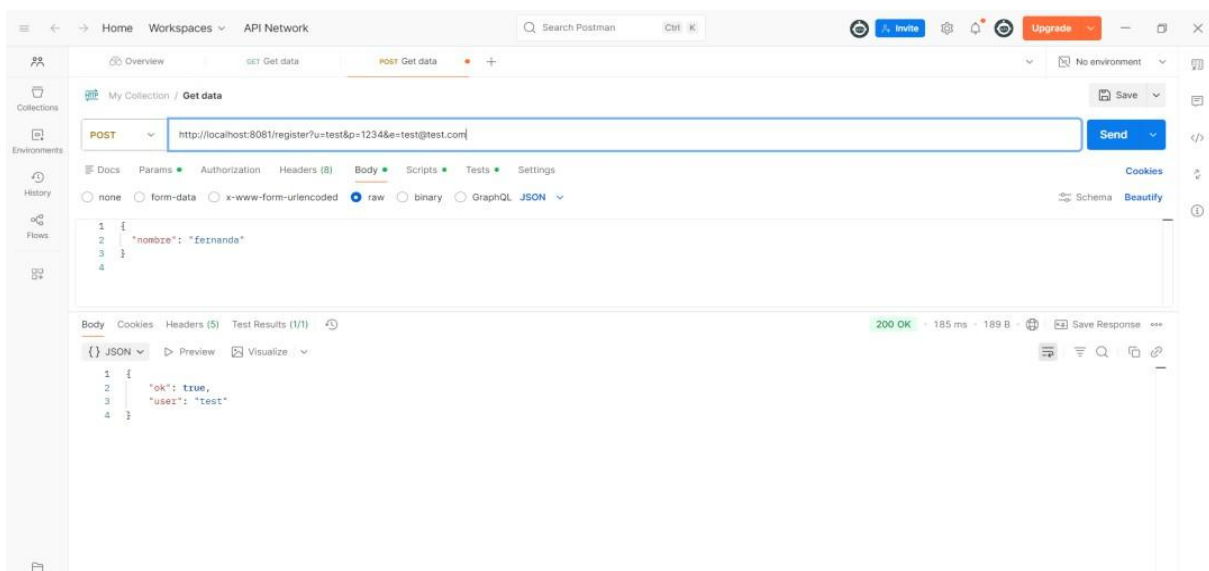


Ilustración 9-Prueba de endpoint POST en Postman — registro de usuario exitoso (200 OK)



¿Cuál fue rechazado?

- p=123 → Rechazado (ok: false)
- p=1234 → Aceptado (ok: true)

¿Es esa validación suficiente?

No.

El sistema únicamente valida una longitud mínima básica (mayor a 3 caracteres), pero permite contraseñas extremadamente débiles como:

- 1234
- 0000
- abcd

No exige:

- Longitud segura (≥ 8 caracteres)
- Combinación de mayúsculas/minúsculas
- Números obligatorios
- Caracteres especiales

Conclusión

El sistema implementa una validación mínima de longitud, pero la política de contraseñas es insuficiente para un entorno productivo. Permitir contraseñas triviales representa un riesgo alto de compromisos mediante ataques de fuerza bruta o diccionario.

📍 Sede Quirinal: Calle 21 No. 6 - 01

📍 Sede Prado Alto: Calle 8 No. 32 – 49 PBX: (608) 8754220

📍 Sede Pitalito: Carrera 2 No. 1 – 27 - PBX: (608) 8350459

✉ Email: contacto@corhuila.edu.co - www.corhuila.edu.co

Personería Jurídica Res. Ministerio de Educación No. 21000 de Diciembre 22 de 1989
NIT. 800.107584-2



CORPORACIÓN UNIVERSITARIA DEL HUILA - CORHUILA
"Diseño y prestación de servicios de docencia, investigación y extensión de programas de pregrado y posgrado, en sus sedes Neiva y Pitalito"